



Goddard Procedural Requirements (GPR)

DIRECTIVE NO. GPR 7120.4E
EFFECTIVE DATE: March 5, 2024
EXPIRATION DATE: March 5, 2029

APPROVED BY Signature: Original Signed By
NAME: Deirdre Healey
TITLE: Director, Safety and Mission Assurance

COMPLIANCE IS MANDATORY

Responsible Office: 300/Safety and Mission Assurance (SMA) Directorate

Title: Risk Management Procedural Requirements

PREFACE

P.1 PURPOSE

This directive specifies the procedural requirements for the implementation of Risk Management at the Goddard Space Flight Center (GSFC) in accordance with GPD 7120.4, GSFC Risk Management Policy, consistent with requirements of NPR 8000.4, Agency Risk Management Procedural Requirements.

P.2 APPLICABILITY

- a. This directive applies to all organizational units performing work that is in-scope of the GSFC Management System as defined as in GPR 1280.1, The GSFC Quality Manual.
- b. In this directive, all document citations refer to the latest version unless a specific version is noted.
- c. In this directive, all mandatory actions (i.e., requirements) are denoted by statements containing the term “shall”. The terms “may” or “can” denote discretionary privilege or permission; “should” denotes a good practice and is recommended but not required; “will” denotes expected outcome; and “is/are” denotes descriptive material.

P.3 AUTHORITY

- a. GPD 7120.4, GSFC Risk Management Policy

P.4 APPLICABLE DOCUMENTS AND FORMS

- a. NPD 1000.5, Policy for National Aeronautics and Space Administration (NASA) Acquisition
- b. NPD 2810.1, NASA Information Security Policy NPR 7120.5, NASA Space Flight Program and Project Management Requirements
- c. NPR 7120.5, NASA Space Flight Program and Project Management Requirements
- d. NPR 7120.7, NASA Information Technology and Institutional Infrastructure Program and Project Management Requirements.
- e. NPR 8000.4, Agency Risk Management Procedural Requirements
- f. GPR 1280.1, GSFC Management System Manual
- g. GSFC-HDBK-8005, Guideline for Performing Risk Assessments

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

P.5 CANCELLATION

GPR 7120.4D, Risk Management

P.6 SAFETY

None.

P.7 TRAINING

Organizational Unit Managers ensure that personnel in their organizational units with delegated responsibility for risk management are trained in the requirements and procedures of NPR 8000.4 and GPD 7120.4, this directive and the organizational unit's Risk Management Plan.

Note: Appropriate Risk Management Training can be accomplished taking courses offered in SATERN and Appel program.

P.8 RECORDS

Record Title	Record Custodian	Retention
Risk Management Plan Program/projects	Organizational Unit Manager	*NRRS 08/103.0 – Temporary cut-off records at close of Program/Project in 5 years blocks destroy/delete between 0 and 30 years after cutoff.
Risk Management Plan – Institutional Risk – Personnel Safety	Organizational Unit Manager	*NRRS 01/121.0.B - Retire to FRC when 4 years old. Destroy when 20 years old.
Risk Management Plan – Institutional Risk - Cybersecurity	Organizational Unit Manager	*NRRS 02/027.0.G - Destroy 3 years after all necessary follow-up actions have been completed.
Risk Register/Database	Organizational Unit Manager	*NRRS 08/101.0 – Permanent. Cut off records at close of Program/Projects or in 3-year blocks for long term Program/Projects.

*NRRS 1441.1 – NASA Records Retention Schedules

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO.	<u>GPR 7120.4E</u>
EFFECTIVE DATE:	<u>March 5, 2024</u>
EXPIRATION DATE:	<u>March 5, 2029</u>

Page 3 of 38

P.9 MEASUREMENT/VERIFICATION

Compliance with this directive will be assessed by the GSFC's Management Systems Branch by sampling Organizational Units across the Center at least once every 3 years and as required by Center Director or Center's Chief Risk Officer (CRO). Non-compliances from the assessment are recorded and tracked through closure in the Management Systems Assessments database.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT
<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

PROCEDURES

CHAPTER 1: RISK MANAGEMENT

1.1 OVERVIEW

- a. GSFC's Risk Management Program provides a unified risk management structure that applies to all Center activities and all applicable risks and interactions and is integrated across organizational domains to ensure that risk management decisions are delegated and/or elevated to the appropriate level. It is also the program's objective that every organization has access to the information needed from subordinate organizations to effectively manage risks at its level.
- b. Risk Management includes opportunity management — recognizing that spaceflight is an inherently risky endeavor and that the proper attitude towards risk management is to reach an optimal balance between minimizing the potential for loss while maximizing the potential for gain (opportunity). The various forms of Risk Management that are being pursued at NASA and GSFC include:
 - (1) Program/Projects Risks: The management of risks across mission execution domains: safety, technical performance, cost, physical security, cybersecurity, and schedule.
 - (2) Institutional Risks: The management of risks associated with development and maintenance of mission support capabilities including qualified technical staff, support staff, information technology, physical security, cybersecurity, facilities, and equipment.
 - (3) Acquisition Risks: The management of risks associated with the acquisition process and the oversight of contractors charged with delivering products and services to the Organizational Unit of GSFC organization.
 - (4) Enterprise Risks: The integration of all forms of risk management together with opportunity management into an overall Risk Management approach that cuts across the entire organization and applies to all GSFC and/or NASA activities.
- c. The overall GSFC Risk Management (RM) process includes two key components used iteratively: Risk-Informed Decision Making (**RIDM**) and Continuous Risk Management (**CRM**). The RIDM component supports decision-making at each management tier by applying quantitative and/or qualitative risk information to achieve organizational objectives and meet requirements in an optimal manner as possible. CRM is applied to facilitate implementation of the mitigation strategies for any risks that are unavoidable after the selection of an optimal approach from the RIDM process is selected.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

1.1.1 Risk-Informed Decision Making

- a. As prescribed by the Agency Risk Management Procedural Requirements (NPR 8000.4 latest version), when a programmatic mission is defined, the Organizational Unit (Institutional risks) and/or Program/Project shall initiate the RM process to formulate a plan for achieving the objective and communicating the risks and mitigation strategies using the following steps:
 - (1) **Identification of Alternatives:** Consider challenges or opportunities based on objectives both tactical and strategic.
 - (2) **Analyze Alternatives (Analysis of Alternatives – AoA):** Apply subject matter expertise across disciplines as needed to document bound risk scenarios, integrate all key drivers and impacts, and consider performance measures.
 - (3) **Risk-informed Alternatives Selection:** After a deliberative review informed by risk analysis results, select a decision alternative based on documented AoAs, and develop risk mitigation strategies.
- b. This approach is particularly useful when a mission entails high risk, complexity, uncertainty, multiple attributes or competing objectives, or a diverse range of stakeholders.

1.1.2 Continuous Risk Management

- a. Organizational Units and/or Program/Project should implement risk management using the following key steps:
 - (1) **Identify:** State the risk in terms of an existing condition that may lead to degraded performance and capture the risk context, including key drivers.
 - (2) **Analyze:** Perform quantitative/qualitative assessments to determine risk likelihood (or probability) and severity of consequences (impact of degraded performance). Consider the timeframe for action. Consider grouping with similar or related risks and prioritize.
 - (3) **Plan:** Assign a risk owner and develop a mitigation plan (handling strategy), develop contingency plan and decide what will be tracked. The level of mitigation should be commensurate with the threat complexity and end goal.
 - (4) **Track:** Acquire/update, compile, analyze, and organize risk data (e.g., technical performance data, cost, schedule) and report tracking results. Verify and validate mitigation actions over time.
 - (5) **Control:** Evaluate tracking data to verify effectiveness of mitigation plans, making adjustment (e.g., re-plan, close the risk, invoke contingency plans, or watch). Execute the risk control decisions.
 - (6) **Communicate and Document:** Report status at predefined time intervals (monthly/quarterly or as mutually agreed between the stake holders) and request direction or concurrence at the appropriate decision level. Document supporting information to track details, plans, progress, and risk decisions.

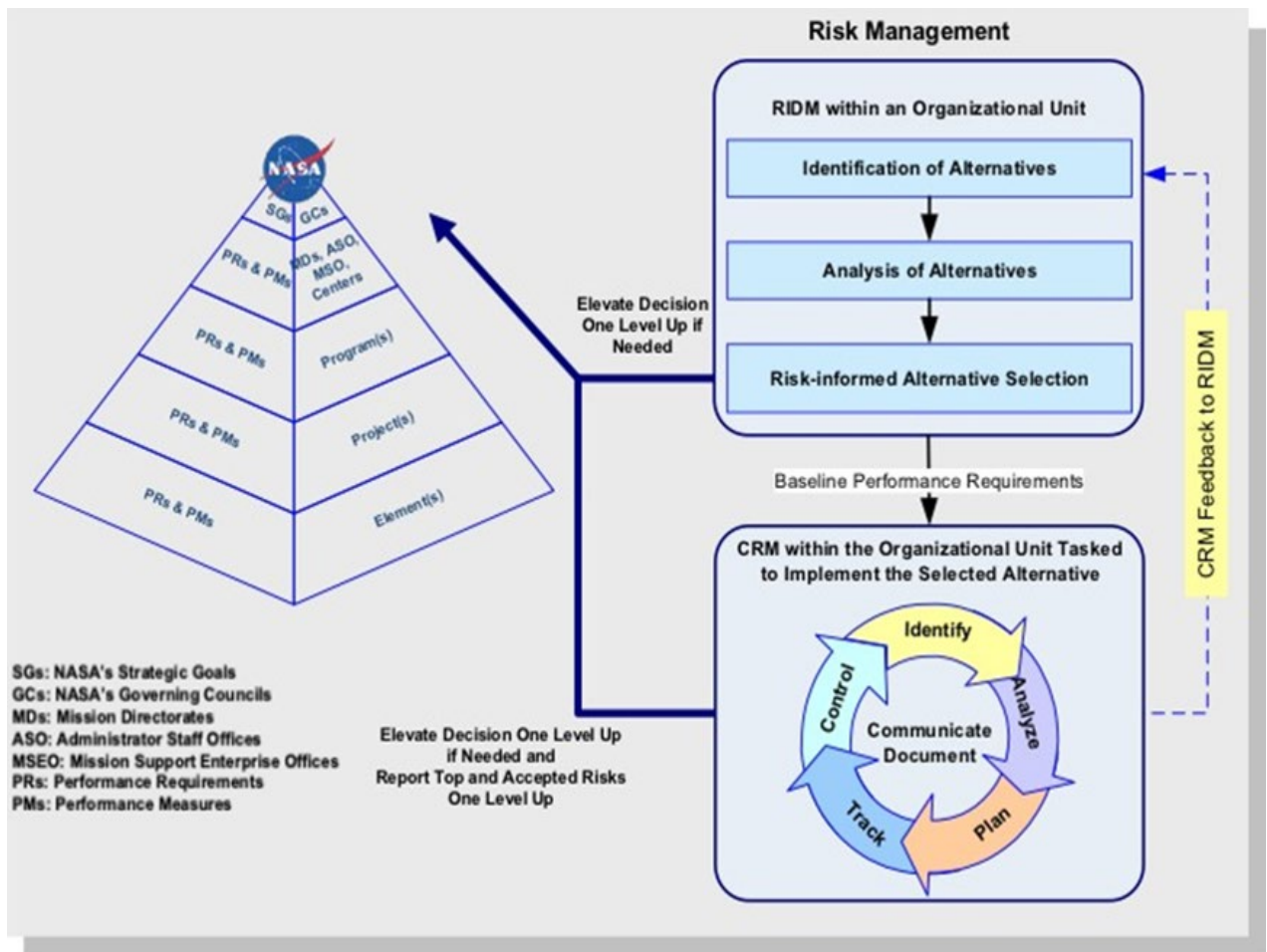


FIGURE 1: Coordination and Integration RIDM-CRM Risk Management Process

Application of RIDM and CRM uses a graded approach, which means the level of risk mitigation and prioritization should be commensurate with the complexity of the risk or severity of consequence if a risk is realized. This process also allows flexibility to recalibrate the risk LxC when reassessed at higher levels. These factors dictate the rigor applied to make a risk-informed decision through a well-coordinated and integrated RIDM-CRM process (see Figure 1).

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

1.2 Potential Program/Project Risk Areas

Potential adverse impacts to GSFC Program/Project risks include but are not limited to:

- a. Safety
- b. Technical Performance (Mission Success)
- c. Cost
- d. Schedule

Note 1: From a center risk management perspective, physical security and cybersecurity risks will be framed in terms of the four risk areas mentioned above. This can be addressed in the specific Project Protection Plan (PPP) document related to that project.

Note 2: Cost and Schedule risks are also called Programmatic risks

1.3 Potential Institutional Risk Areas

Potential adverse impacts to GSFC institutional risks include but are not limited to:

- a. **Health, Safety and Environment (HSE)**
 - (1) HSE-Personal Injury/Illness
 - (2) HSE-Property Damage – Cost
 - (3) HSE-Compliance – Occupational Safety and Health Administration (OSHA) and Environment
- b. **Technical Performance (TP)**
 - (1) TP-Infrastructure and Asset Impacts
 - (2) TP-Organizational Objectives
- c. **GSFC and Agency Capabilities (GC)**
 - (1) GC-Service Delivery (Physical Security & Cybersecurity)
- d. **Workforce** (includes Technical Excellence)
- e. **Cost** - Organizational Budget Impacts
- f. **Schedule** - Project Timelines

CHAPTER 2: ROLES AND RESPONSIBILITIES

2.1 Center Director

Center Director and/or his/her delegated authority is accountable for risk acceptance decisions for institutional activities.

2.2 Safety and Mission Assurance (SMA) Director

The SMA Director:

- a. Approves the Center risk management procedure.
- b. Appoints the Center Risk Officer and Code 300 Risk Manager.

2.3 Center Risk Officer (CRO)

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO.	<u>GPR 7120.4E</u>
EFFECTIVE DATE:	<u>March 5, 2024</u>
EXPIRATION DATE:	<u>March 5, 2029</u>

The CRO and/or designee:

- a. Serve as the point of contact for Center risk management activities, procedures, and processes.
- b. Develop Center risk management policy and procedure and keep it current with latest applicable NASA requirements.
- c. Ensure that risk management plans are developed, approved, and implemented.
- d. Concur with risk management plans for directorates, Code 100 Offices, and Programs/Projects and facilitate coordination of cross-cutting risks especially related to programs/projects and institutional.
- e. At monthly Center Risk Board meetings, presents GSFC top institutional risks by closely working with all directorates and incorporating input from Institutional Operations Council (IOC).
- f. Prepare and communicate GSFC Top Risks to HQ-OSMA as requested.
- g. Represent GSFC in Agency Risk Management Working Group (ARMWG) led by OSMA and Mission Support Directorate Risk Management Working Group (MSD RMWG) activities to meet current and evolving risk management processes and practices across the agency.

2.4 Organizational Units - Directorates and Programs/Projects

- a. Develop and implement a risk management plan.
- b. Assign a point of contact for risk management.
- c. Inform Center management of significant risks at Center Risk Board and/or at Center Management Council (CMC) during Monthly Status Review (MSR) week and/or at Institutional Operations Council (IOC), depending on the nature of the risks (program/projects, institutional, cross-cutting, or strategic) to GSFC operations/enterprise.
- d. Take Individual Accountabilities for Risk Acceptance
 - (1) Programmatic authorities, e.g., project managers, have risk leadership responsibility and are accountable for risk acceptance decisions for their programs or projects, to be produced in timely fashion, and commensurate with their delegated authority and with the risk posture established for such activities or projects.
 - (2) Organizational units are responsible for accepting the institutional risks in their respective Directorate.

2.5 Program/Projects, Directorate and Councils Point of Contact (POC)/Risk Manager

The Risk Management POC/Risk Manager:

- a. Ensure development, approval, and implementation of a risk plan.
- b. Assist personnel in developing risk information.
- c. Facilitate discussions related to risk formulation, tracking, and retirement.
- d. Develop and manage a RM process for their project/organization that complies with this document and elevate risks to the appropriate levels.
- e. Ensure availability of appropriate risk management training.

2.6 Mission Support Organizations to Goddard Center Director

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO.	<u>GPR 7120.4E</u>
EFFECTIVE DATE:	<u>March 5, 2024</u>
EXPIRATION DATE:	<u>March 5, 2029</u>

- a. Inform GSFC Center management regarding significant Goddard operations/enterprise risks at Center Risk Board and/or at CMC during MSR week and/or at IOC, depending on the nature of the risks (program/projects, institutional, cross-cutting, or strategic).
- b. Assign a point of contact for Goddard risk management to CRO.
- c. Implement requirements of this document to meet Goddard programmatic and institutional needs.

CHAPTER 3: RISK MANAGEMENT FUNDAMENTALS

Risk is a threat with sufficient information to indicate a negative consequence when measured against a safety, technical, cost, or schedule performance objective. Risk is also the potential inability to fully implement agreements with NASA stakeholders or partners (commercial, governmental, or international). Resolution requires focused management attention. Some foundational aspects of risk management and risk assessment are covered in GSFC-HDBK-8005 (8005), including the concept of the *concern*, upon which a risk is founded, but which lacks the full context or scenario for risk. In 8005, safety, technical, and programmatic concerns are introduced as the bases for all categories of risk. In addition, based on NPR 8000.4, cybersecurity and physical security are introduced here as additional areas of concern, but the outcomes of such concerns may always be categorized as safety, technical, or programmatic as applicable for the given risk scenario, which will be the standard practice in this directive.

3.1 Risk Identification

Risk management begins with identification of a perceived shortfall against a performance objective, including key drivers and impacts.

3.1.1 Risk identification is a continuous effort to capture, acknowledge and document risks as they are identified based on a condition; event; or review of requirements, products, and services needed to execute a planned mission. Emphasis is on early identification of risks related to HSE, Technical Performance, Center capabilities (infrastructure, personnel), and cost or schedule threats. Risks also may be identified when implementing corrective or preventative actions.

3.1.2 Examples of key considerations for risk include:

- a. Funding requirements and priority: Likelihood of budget shortfall and rationale, impact if not funded (e.g., reduced scope, impact to internal/external stakeholders), risk buy-down that would be achieved with full or incremental funding.
- b. Cross-cutting risks: A risk-owning organization has primary impact, but based on potential risk handling/disposition and mitigation timeframe, consequences also may impact one or more NASA organizations or external stakeholders.
- c. Center capabilities: Infrastructure and resources as required for achievement of institutional objectives and Program/Project support requirements.
- d. Transition planning: Requirements for changing Agency or Center conditions or objectives.

3.1.3 An identified risk shall be documented in a risk statement in the following format:

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

“Given that [condition], there is a possibility that [intermediate consequence] will occur with the result that [consequence].” [See figure 2]

Note 1: Provide Context statement to identify key background details.

Note 2: No conditional statements may appear in the *condition*, *intermediate consequence*, or in the *consequence*, as such would render the likelihood arbitrary.

Note 3: Similar formats may be used without waiver as long as they start with factual context, end with a mission or institutional level consequence, and are free of conditional terms outside of one conditional statement that is part of the format itself.

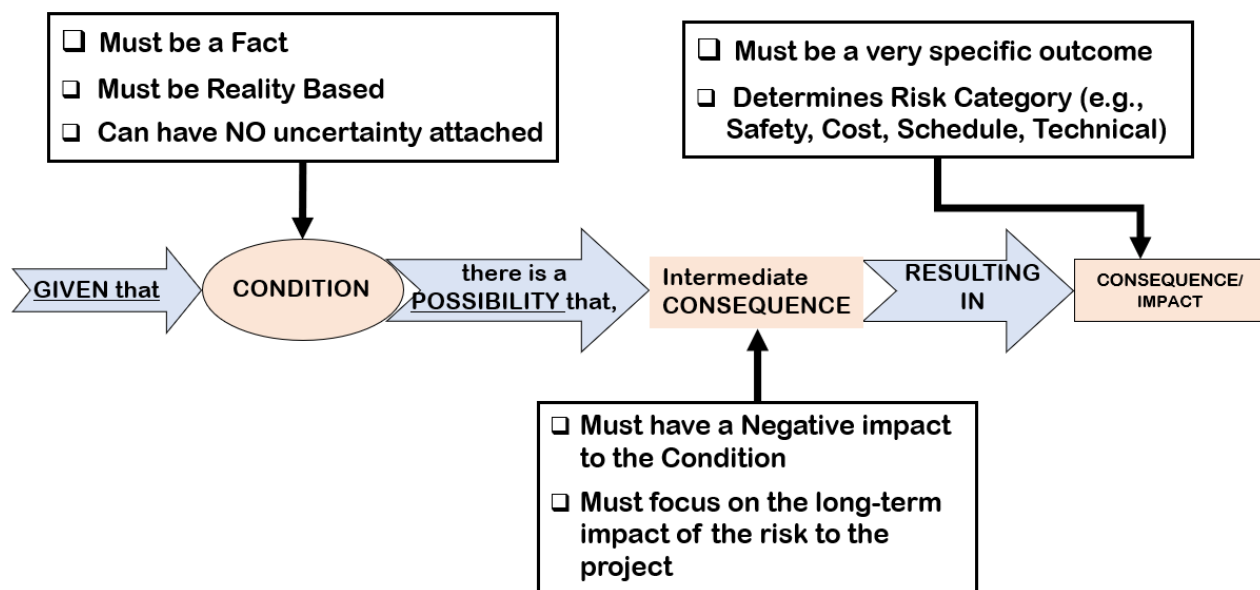


Figure 2: Risk Statement Structure

3.1.4 A candidate risk with information that is insufficient or immature to analyze or define mitigation options may be captured as a Concern in a list maintained by the Organizational Unit. Concerns may be managed internally within existing resources and processes. The concern may be elevated to a risk with documented supporting details and then to the next higher level as needed.

3.1.5 Organizational Units should form *Risk Boards*, chaired by the organizational leaders or designees, to determine whether risks are valid or invalid, and whether they should be owned by their respective Organizational Unit or project or an outside entity. Project-owned, valid risks should be tracked in a project risk repository, commonly denoted the project *risk register*.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

3.2 Risk Analysis

3.2.1 Risks shall be analyzed to determine likelihood of occurrence and its consequence to the performance objective. In accordance with RIDM-CRM principles (NPR 8000.4), the risk analysis steps are as follows:

- Evaluate risk data. Identify and understand the consequence/impact from each risk contributor, including the uncertainty inherent in each.
- Assess Risk Likelihood (L): Perform quantitative and/or qualitative analysis in assessing risk likelihood.
 - Quantitative risk analyses are preferred and shall be applied to the maximum extent practical. Use of quantified analysis is based on scope of the decision to be made and similarities among suitable alternatives (graded approach).
- Assess Risk Consequence (C): Assess risk consequences in its impact to the Organizational Unit for specific risk category with respect to degraded performance, loss of function, key milestone slip, personal injury, cost escalation or loss of mission etc.
- Select one or more analysis methodologies for each consequence, for example:
 - Analysis of historical data (similarity)
 - Quantitative analyses including assessment of associated uncertainties
 - Maintenance, Repair and Replacement (MRR) cost estimates
- Determine the risk of cost impact. Identify all constraints and thresholds (For more details see Section 3.2.2).
 - Include the cost threat for all applicable fiscal years.
 - Constrain assessment of risk consequences to the current Planning, Programming, Budgeting and Execution (PPBE) period, to provide a consistent frame of reference.
- Categorize the risk likelihood and consequence: Map risk assessment results to the descriptions listed on the GSFC Risk Scorecard (Appendix C). Figure 3 reflects the risk significance score to the assessed LxC and helps prioritization of risks within and across any Organizational Units.

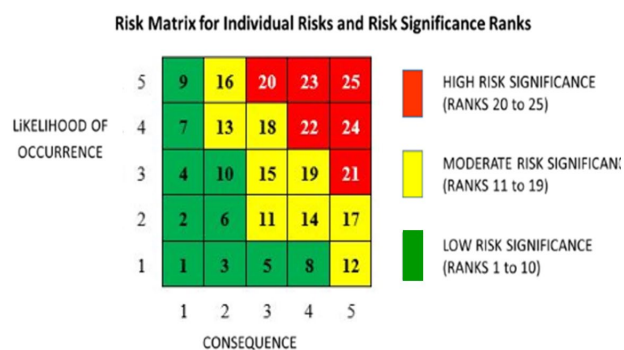


Figure 3: Risk Matrix for Individual Risks and Risk Ranking

Note: A risk with a likelihood that is below the floor of a likelihood of “1” or a consequence that is less severe than a consequence of “1” on the pertinent scale is deemed “noncredible”. Ensure that the

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO.	<u>GPR 7120.4E</u>
EFFECTIVE DATE:	<u>March 5, 2024</u>
EXPIRATION DATE:	<u>March 5, 2029</u>

consequence impact is assessed from the overall system's perspective and not at the component or box level.

- g. Communicate the risk. The risk manager/owner shall periodically review/update risk status, communicate/present risk status updates at Organizational Unit management forum at predefined time intervals with full supporting details, validate new concerns and review updates of mitigation plan actions. Organizational Unit will determine if the risk requires escalation to the next level, remains unchanged and/or requires de-escalation to a lower level. At the Center-level, risks will be reviewed monthly, alternating between internal reviews with the Center Managers and reviews with the applicable full GSFC Management Council (GMC), and cross-cutting and strategic risks will be identified that need to be brought forward to the CRB and/or the Mission Directorate.
- h. Document expected likelihood and consequences in the project-level risk list, risk database or risk tracking tool.
- i. Risk-Informed Alternative Selection: Select an Alternative and Accept the Associated Risk Informed by Risk Analysis, and document results of Analysis of Alternatives (AoA), the decision and its supporting rationale.
- j. Perform Risk Aggregation: Risk aggregation is the accumulation of the total risk exposures of various types of threats throughout the program/projects and/or the organizational unit's portfolios including the timeline. Risk aggregation should be performed qualitatively for missions governed by NPR 7120.5 and may be required by a higher authority as a precursor to a major decision, such as shipment to a launch site. An example of such an aggregate risk assessment is portrayed in 300-STM-1015.
- k. Assess Cross-cutting risk: Cross-cutting risk assessment is the analysis of risks across multiple domains to determine possible common causes, solutions, mitigations, etc., to avoid redundant or conflicting responses. It is the responsibility of the participants in various risk boards and forums on Center to watch for linkages among related risks in multiple domains. An example of a cross-cutting risk assessment process is illustrated in 300-PG-8730.1.1 (Cross-Cutting Issue and Systemic Trend Identification and Resolution).

3.2.2 Impact of Liens, Threats, and Encumbrances on Project Unallocated Future Expenses (UFE)

Risks are a key element in understanding the potential cost liabilities that a program or project may incur. The purpose of this section is to establish the method for determining the potential cost impact associated with risks. This section provides definitions for the terms to categorize the real and potential reductions to budget contingency, and the requirements for calculating and applying them for budgeting and reporting purposes. The intent is to provide a more realistic reflection of potential project cost growth.

Whether a risk is a threat or a lien – and the magnitude of its calculated cost impact – depends on its placement on the 5x5 risk matrix. For 7120.5 projects, risks having cost or schedule impacts shall be reported and shown against project held UFE levels as part of budget submissions and Monthly Status Reviews (MSR). Overall Goddard project held UFE Management guidance and directions are included in GPR 7120.7. Situations or circumstances that have either already occurred or are inevitable regardless of risk management strategy should be identified as issues, not as risks.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

a. Threat, Lien, and Encumbrance Definitions:

- (1) Threats are all risks (red, yellow, and green) with a likelihood (L) of 1, 2, 3 or 4 that have potential cost impacts.
- (2) Liens are all risks with a high certainty of occurrence (likelihood L=5, or Issues) that have potential cost impacts (liens are usually realized, at least in part). The cost value of a lien may still be uncertain and be under refinement.
- (3) Encumbrances are issues/risks that are fully realized and have a final cost impact.

There may be unusual circumstances where a lien or threat is not associated with a risk, but, in general, all threats and liens should result from risks. Items not related to risks that are 100% probable but that have not yet occurred, e.g., pending cost overruns or changes in scope that require project held UFE usage, shall be assigned a L of 5 and carried as liens. A risk for which the potential outcome has occurred is an issue and the project may determine whether there is also a remaining element of the risk, before or after the issue has been addressed.

b. Threat, Lien, and Encumbrance Calculations:

- (1) Threats shall be calculated and budgeted based on an assessment of likelihood, consistent with placement on the risk matrix, according to the following:

Expected Value of the Threat = Probability (P) x Estimated Cost Impact.

P = 10% for L of 1 (Very Low)

P = 20% for L of 2 (Low)

P = 40% for L of 3 (Moderate)

P = 60% for L of 4 (High)

Lien for L of 5 (very high)

- (2) Liens shall be calculated and budgeted at 100% of the estimated cost impact.
- (3) Encumbrances shall be budgeted at 100% of the final cost impact.

3.3 Risk Documentation

3.3.1 As risks are identified and mitigation strategies developed, the Risk POC should ensure that following details are provided as part of submitted risk:

- a. Risk Title
- b. Risk ID#
- c. Risk Owner
- d. Risk Statement
- e. Risk Category (from applicable Program/Project Risk Score card and/or Institutional Risk Score Card)
- f. Likelihood x Consequence (LxC) Score and Rationale

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- g. Risk Description (including context -include time horizon)
- h. Impact/Consequences
- i. Estimated Completion Date (ECD) and the rationale for acceptance and criteria for risk closure or acceptance
- j. Current Status
- k. Handling Strategy and task mitigation steps (with detailed burndown plan, timelines)
- l. Cost impact, if known.

3.4 Planning (Handling Strategy)

3.4.1 The Risk Owner is responsible to ensure that the plan of action for each risk, referred to as the handling strategy, is carried out.

3.4.2 Options for Handling Strategy

The intent of a handling strategy is to minimize the LxC over time. However, the option to “Do Nothing” should be addressed first. Then, the preferred strategy and supporting data are approved at the appropriate management level. Options include:

- a. Research – Consider and review all pertinent information sources to understand the risk.
- b. Mitigate – If “do nothing” is not acceptable, develop a mitigation strategy to measurably reduce the LxC. Specify the mitigation ECDs, resulting LxC score and rationale, and success criteria.
- c. Watch – For risks where circumstances do not warrant immediate mitigation steps, define triggers that indicate the need for action. These trigger events should include decision points such as milestone reviews, necessary achievements and a timeframe for re-evaluation and active mitigation or alternate handling strategies.
- d. Accept – If further mitigation is not cost-effective and no further resources will be expended to mitigate residual risk, a risk owner may recommend ceasing active mitigation with key assumptions and conditions on which the decision to accept will be based. To accept a risk, rationale must be approved by the owning organization and key stakeholders. Periodically assess for changing conditions.

Note: The Project Manager is accountable for risk acceptance for flight projects, while the Center Director is accountable for risk acceptance for institutional risks, with delegation to pertinent Organizational Unit leaders. Risks accepted by the Project Manager are recorded in the respective project’s risk database, with concurrence by the technical authorities of that project: Mission Systems Engineer and Chief Safety and Mission Assurance Officer. Institutional accepted risks are tracked within the pertinent organization’s risk databases. Concurring authorities for the acceptance of institutional risks are dependent upon the pertinent Organizational Unit.

3.4.3 Risk Escalation

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Risk owners should perform due diligence with affected stakeholders to understand the risk scoring rationale, and ranking, to determine if a risk should be escalated to the next level. Reasons for escalation may include:

- Additional resources are needed to mitigate the risk.
- Direction is needed from the next level of management.
- External integration is required (for example, with other programs/projects/centers).
- The risk has cross-cutting significance.

Escalation should reflect the hierarchical level of insight or control of resources needed to handle the risk. The risk escalation process is iterative to accommodate changes to a risk throughout its life cycle.

Each Organizational Unit shall review its risks on a periodic basis (Figure 4). The following levels are defined to support the Center's escalation process:

- Center Risks/Problems/Issues – Requires Center management resources or direction to resolve; could have cross-cutting impacts that affect two or more GSFC organizations.
- Organizational Unit/Directorate Risk – Requires Directorate Management direction and/or resources to resolve; affects one or more divisions within the Directorate.
- Sub-Organizational Unit Risk – Requires Division/Branch Management direction and/or resources to resolve; affects one or more sub-organizations.

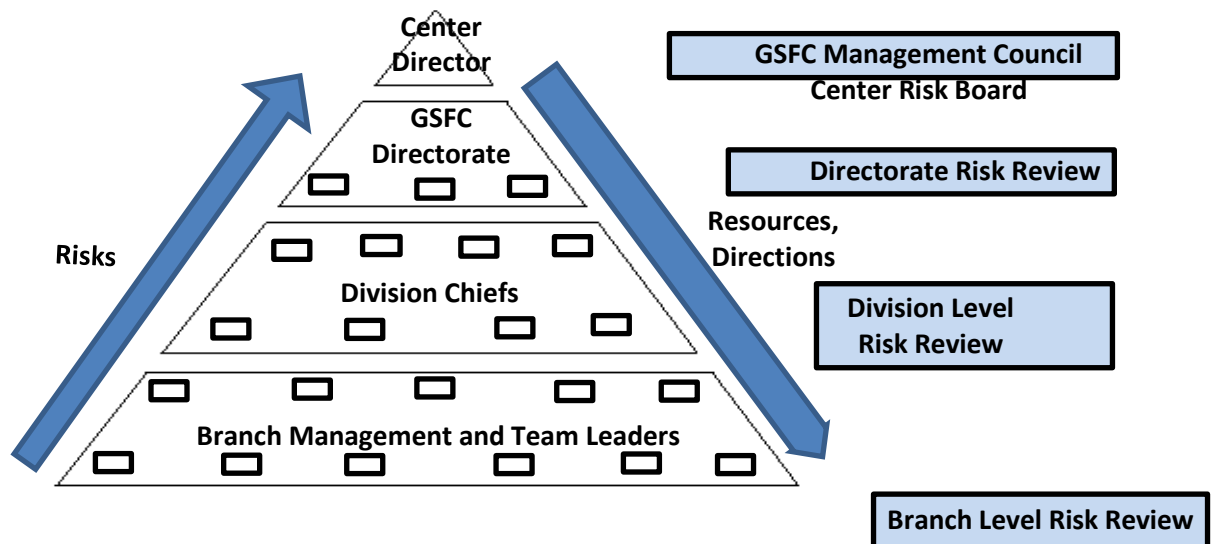


Figure 4: GSFC Risk Management Hierarchy

If the Risk Owner does not have the resources or authority to perform the mitigation actions, the risk should be reassigned to an individual or organization that has such capacity and resources to mitigate. This may be in the form of an escalation, transfer, or reassignment to a lower level. The proposed risk is presented to appropriate management level for approval of content, resource requirements, and priority

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

ranking. The Risk Owner changes the risk level designation in the respective Organizational Unit database. When reassigned, risk scores may change and/or be adjusted to reflect the significance of the impact at the next level.

For Center organizations with Organizational Unit/Program risks requiring Program Management or Mission Support Directorate direction and resources to resolve, escalate risks via the MSD/program's risk review process. Coordinate any cross-cutting risks with all affected Center Organizational Units.

3.5 Risk Tracking

3.5.1 The risk owner shall track risk attributes over the risk life cycle to determine if: 1) mitigation steps are performed in a timely manner and 2) steps taken are effectively managing the risk. The owner tracks observable data related to performance measures such as cost/schedule variance or changing conditions.

3.5.2 The Risk Managers track and update risks on a recurring basis to reflect current status and progress and use the results to communicate risk status and information (quantitative or qualitative) as required for effective control and management decisions.

3.5.3 The risk tracking data are reported to Organizational Unit Managers at the MSR and/or as requested.

3.6 Risk Control

Risks are a key input to the Risk Control process and reflect specific challenges to meeting commitments. Recommendations for resource allocation take into consideration the trade-offs between finite resources and prioritized risks. Collaboration with GSFC organizations is essential for incorporating risk management into the Center Management decision-making process.

3.6.1 The risk control function is to assess and verify that the mitigation plan is effectively reducing the LxC threat. In addition to process steps in paragraph 3.4.2, based on analysis of tracking data, types of control decisions may include:

- a. Continue as planned – Progress is satisfactory (as expected).
- b. Re-plan – Mitigation is not achieving the desired outcome or conditions have changed.
- c. Invoke a contingency plan – If the current plan proves inadequate to mitigate the risk, a previously approved alternative is implemented.
- d. Close – To close a risk, rationale is approved at the appropriate management level to demonstrate that the risk has been eliminated; residual risk is negligible such that further steps are unnecessary; or the threat has been subsumed by a new risk. Risk closure rationale/decision are documented in the OU database.
- e. Transfer – To re-allocate the risk to an organization that is better suited to handle the risk mitigation processes, which is mutually agreed upon by the affected parties.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

3.7 Risk Communication, Reports and Recommendations

Relevant risks are deliberated, recommended, and prioritized as Top Center Risks/Problems/Issues or Proposed Top Center Problems/Issues and are reviewed at GSFC Management Forums such as IOC, CMC (MSR forum) and/or CRB. Summary reports are generated and presented based on risk information in the Organizational Unit risk database or equivalent. Recommendations may derive from related Center, Directorate, and Program/Project risk review forums.

- a. Center Management Council (CMC) – MSR forum: Three-leg reporting (Program/Projects Manager, Chief Safety Officer, Mission Systems Engineer, Other organizational units)
- b. Institutional Operations Council (IOC) - Institutional Risks
- c. Center Risk Board (CRB) - Center Enterprise Risk Management Process
- d. Mission Directorate (MD) - Programs/Projects Risks
- e. MSD - Mission Support Directorate - Institutional Risks
- f. BPR - Baseline Performance Review at NASA HQ

3.8 Process for Handling Formal Dissent

Resolution for formal dissent of any nature is handled in accordance with NPD 1000.0, Section 3.5.4 (for Programmatic and Institutional risks) and NPR 7120.5, Section 3.3 (Programmatic -Technical Authority) when an individual deems it to be of sufficient importance to warrant a specific review and decision by higher-level management. Elevation of formal dissent is performed at the discretion of the dissenting party.

CHAPTER 4: REQUIREMENTS

4.1 Risk Management Process

4.1.1 The Project Manager (PM) and Organizational Unit Managers shall implement a systems management approach that formalizes and integrates the RM process throughout all the phases of the system life cycle (concepts through decommissioning) and addresses all elements of the system (e.g., flight, ground and launch vehicle segments, hardware and software, critical ground support equipment, infrastructure assets, physical security and cybersecurity and other resources).

4.1.2 For NPR 7120.5 projects, Programs/Projects implementation should include the use of tools and methodologies as appropriate to the risk, such as (a) Failure Modes and Effects Analysis (FMEA) – Critical Items Control Plan (as applicable), Fault Tree Analysis (FTA), Hazard Analysis, Inspection, and Quantitative Risk Assessment processes/tools to support the qualitative and quantitative assessment of risk inherent in the system design and (b) other associated engineering modeling and simulation tools during development, (c) process control during manufacturing and inspection, (d) Integration and Testing (I&T) and (e) Operations activities to:

- a. Evaluate alternative design concepts, redundancy and cross-strapping approaches, and part substitutions.
- b. Identify critical processes and associated inspection points.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- c. Identify the elements of the design that are the greatest detractors of system reliability.
- d. Identify those potential mission-limiting elements and components that will require special attention in part selection, testing including design qualification, environmental isolation, and/or special operations.
- e. Assist in evaluating the ability of the design to achieve the mission life requirement and other reliability goals and requirements as applicable.
- f. Evaluate the impact of proposed engineering change and waiver requests on reliability.

Risk assessment results should be used to support decisions and documented in the risk register. The results of these risk assessments should be used to support project management decisions with respect to safety and mission success and programmatic commitments.

Institutional risks are reported at the OU risk management board, Center Management Council (CMC-MSR forum), Institutional Operation Council (IOC) and/or as requested.

4.1.3 The PM shall incorporate the requirements of the Risk-Based Acquisition Management (R-BAM) initiative as part of the RM process (refer Appendix D). The purpose of R-BAM is to convey NASA's focus on safety and mission success to NASA contractors in accordance with NPD 1000.5, Policy for National Aeronautics and Space Administration (NASA) Acquisition.

4.1.4 The PM shall document project-specific implementation of the RIDM-CRM process in a Project/Program Risk Management Plan (RMP). For Projects managed per NPR 7120.5 (Classes A through C missions), the RMP is reviewed by the Chief Safety and Mission Assurance Officer (CSO) and Mission Systems Engineer (MSE), approved by the PM and concurred by the Safety and Mission Assurance Director or designee. For Projects and Single-Project-Programs the RMP is Baseline at SRR and, updated for subsequent milestone Life-Cycle Reviews. The RMP is a controlled document that is maintained by the PM throughout the project life cycle. The administrative rigor of the Risk Management plan should be commensurate with the risk classification and resources available for the mission, particularly for missions Class D and those not under NPR 7120.5.

4.1.4.1 Similarly, Directorates shall develop and maintain their respective RMP to follow RIDM-CRM process to pursue institutional risks affecting their respective organizations.

The Program/Project RMP includes at a minimum:

- a) Introduction - Specify the project risk objectives and policy toward risk. Explain the purpose, scope, assumptions, constraints, key ground rules and policy pertaining to the project RIDM-CRM process.
- b) Overview of process - Provide an overview of the RIDM-CRM process and information flow. Describe how the RIDM-CRM process integrates and relates to other project management and system engineering activities. Include general risk mitigation strategies to be employed throughout project life cycle.
- c) Organization - Show the organization, roles, and responsibilities of program, project, customer,

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

and supplier key personnel about RIDM-CRM processes. Document how team members will be trained in the application of CRM methodology.

- d) Risk acceptance protocol - Organizational unit manager accepts pertinent risks after risk board disposition and documents in the risk register.
- e) Process details - Provide the RIDM-CRM process details and related procedures, methods, tools, and metrics. Include here, or in an appendix, the specific methodologies to be used for risk identification, analysis, planning, tracking and controlling. Include the process to be used for continual assessment of the project risk profile. Describe how risk information will be communicated both internally to the project staff and throughout the NASA management chain.
- f) Document the use of various reliability analyses in the project systems engineering process.
- g) Documentation of risks - Specify the format and data elements that will make up the project Risk Register, how configuration control will be applied and how the list will be used and updated. Tell how team members will be able to access the current list at any time.
- h) Include in the RMP the initial set of identified risks and the action plan (research, accept, track, or mitigate) for each risk.

4.1.5 The PM shall establish criterion of RIDM-CRM training (based on complexity of the mission) early in project formulation for the project team and throughout the life cycle as defined in the RMP. General RIDM-CRM training is available to project personnel via on-line/in-person Appel training and/or SATERN courses.

4.1.6 The PM shall ensure that accepted risks/residual risks are linked to the results of the relevant reliability and/or applicable engineering analysis.

4.1.7 For 7120.5 projects the PM shall report the results of FMEAs, FTAs, numerical reliability assessments, engineering analysis and other analytic tools at system-level critical milestone reviews. The presentations should include descriptions of how the analysis was used to perform design trade-offs and how the results were taken into consideration when making design or risk management decisions.

4.1.8 The PM shall maintain a Risk register throughout the project life cycle, along with programmatic impacts. The list should emphasize yellow and red risks and green risks that require special attention. The list should also identify actions being taken to address each specific risk.

4.1.9 The PM shall communicate risk status on a regular basis to the project team and customers appropriately and to the Program Management Council (PMC) through the MSR.

4.1.10 For each risk, the PM develops and maintains the following information, where applicable:

- a. Description of the risk, including the context for elevated risk, actions embedded in the program/project to date to reduce or control it, and information collected for tracking purposes.
- b. Primary consequences should the undesired event occur. Estimate of the probability (qualitative or quantitative) of occurrence with consideration of the uncertainty of the estimate. The probability of occurrence shall consider the effectiveness of any implemented risk mitigation measures that have already taken place.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- c. Potential additional mitigation measures, including a cost comparison, which addresses the probability of occurrence multiplied by the cost of occurrence versus the cost of risk mitigation.
- d. Risk reporting (see examples in Appendix C, Figures 8 through 10). Only yellow risks and red risks are reported with the exception of select green risks that need special attention.

4.1.11 An organizational unit RMP should follow a similar process in line with its roles and responsibilities. Organizational unit RMP details include items such as risk management RIDM-CRM process details, membership structure of OU's risk boards, frequency of the risk boards, risk acceptance authority and the database where RM meetings and risk details are documented.

CHAPTER 5: ISSUE REPORTING

Issues are risks that have been realized, whether they were identified beforehand or not. The issues should be characterized and scored based on the consequences in their pertinent risk categories (technical, programmatic, safety, institutional such as GSFC/agency capabilities). Issues may affect the objectives set in the three principal domains of NASA-GSFC activity, i.e., the Enterprise, Program/Project, and Institutional Domains. Program/Projects issues are reported during MSR at CMC at GSFC and to the Mission Directorate, and Institutional issues are reported through IOC to the Center.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Appendix A – Definitions

- A.1 Aggregate Risk.** The cumulative risk associated with a given goal, objective, or performance measure, accounting for all significant risk contributors. For example, the total probability of loss of mission is an aggregate risk quantified as the probability of the union of all scenarios leading to loss of mission.
- A.2 Candidate Risk.** A potential risk that has been identified and is pending adjudication by the affected programmatic or institutional authority.
- A.3 Common Cause Failure Risk.** A potential that a failure of two or more components or systems occurs due to a single specific event or failure mode/failure cause.
- A.4 Concern.** A logical determination that an undesired event may occur or that the protections against such an event may not be sufficiently well understood based on available data.
- A.5 Consequence.** The key, possible negative outcome(s) of the current key circumstances, situations, etc., causing concern, doubt, anxiety, or uncertainty.
- A.6 Continuous Risk Management.** A systematic and iterative process that efficiently identifies, analyzes, plans, tracks, controls, and communicates and documents risks associated with implementation of designs, plans, and processes.
- A.7 Cross-cutting Risk.** A risk that is generally applicable to multiple mission execution efforts, with attributes and impacts found in multiple levels of the organization or in multiple organizations within the same level.
- A.8 Credible Risk.** A risk whose likelihood and consequence each are above the floor of a “1” designation on the pertinent risk scale.
- A.9 Cybersecurity.** Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation [source: Office of Management and Budget Memorandum Circular A-130, Managing Information as a Strategic Resource, July 2016].
- A.10 Cybersecurity Risk.** Threats to and vulnerabilities of cyber-assets – i.e., data, information, control systems, and information systems stored and/or implemented in digital form – and any related consequences caused by or resulting from unauthorized access, use, disclosure, degradation, disruption, modification, or destruction of cyber-assets, including such related consequences caused by an act of terrorism [adapted and extended from National Cybersecurity Protection Act of 2014, to explicitly include threats to digital control systems].

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

A.11 Deliberation. In the context of this GPR, the formal or informal process for communication and collective consideration, by stakeholders designated in the RMP, of all pertinent information, especially risk information, in order to support the decision maker.

A.12 Dispositions (of Risk):

- a. Accept.** The formal process of justifying and documenting a decision not to mitigate a given risk beyond some assessed or projected level. (See Section 3.5 and definitions of Risk Acceptance Criterion and Risk Acceptance).
- b. Close.** The determination that a risk no longer exists (e.g., the underlying condition no longer exists), has become a problem and is now tracked as such, because the associated scenario likelihoods are low (e.g., the likelihood has been reduced below a defined threshold), or the associated consequences are low (e.g., the consequence has been reduced below a defined threshold).
- c. Elevate.** The process of transferring the decision for the management of an identified source of risk to the risk management structure at a higher organizational level.
- d. Mitigate.** The modification of a process, system, or activity in order to reduce a risk by reducing its probability, consequence severity, or uncertainty, or by shifting its timeframe.
- e. Research.** The investigation of a risk in order to acquire sufficient information to support another disposition, i.e., close, watch, mitigate, accept, or elevate.
- f. Watch.** The monitoring of a risk for early warning of a significant change in its probability, consequences, uncertainty, or timeframe.

A.13 Graded Approach. The application of risk management processes at a level of detail and rigor that adds value without unnecessary expenditure of unit resources. The resources and depth of analysis are commensurate with the stakes and the complexity of the decision situations being addressed.

A.14 Information System. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information [from 44 U.S.C., Sec. 3502].

A.15 Institutional Risks. Risks to infrastructure, information technology, resources, personnel, assets, processes, operations, occupational safety and health, environmental management, security (physical security and cybersecurity), or programmatic constraints that affect capabilities and resources necessary for mission success, including institutional flexibility to respond to changing mission needs and compliance with internal (e.g., NASA) and external requirements (e.g., Environmental Protection Agency or Occupational Safety and Health Administration regulations).

A.16 Intentional Threat. A threat originated, directly or indirectly (e.g., via the use of automated machinery or digital equipment) by human agents. See also *Threat*.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- A.17 Issues:** Risks that have been realized, whether they were previously recognized or tracked or not.
- A.18 Knowledge Management.** Getting the right information to the right people at the right time and helping people create knowledge and share and act upon information in ways that will measurably improve the performance of NASA and its partners.
- A.19 Likelihood.** Probability of occurrence, expressed in either qualitative (e.g., “Low, Moderate or High”, or in quantitative terms.
- A.20 Mission Directorates:** Provides services and capabilities that ensure NASA has the technical skills, physical assets, financial resources and top talent to pursue space exploration and to accomplish mission success.
- A.21 Mission Support Directorate (MSD) –** Provides institutional support for NASA to successfully conduct Space Exploration Missions while keeping its people and its operating systems safe.
- A.22 Organizational Unit.** An organization, such as a program, project or directorate (for Institutional Risks) that is responsible for carrying out a particular activity.
- A.23 Opportunity.** A strategic or tactical initiative that would have potential future benefits to the program’s and/or institution’s cost, schedule and/or performance baseline.
- A.24 Performance Measure.** A metric used to measure the extent to which a system, process or activity fulfills its intended objectives.
- A.25 Performance Requirement.** The value of a performance measure to be achieved by an organizational unit's work that has been agreed upon to satisfy the needs of the next higher organizational level.
- A.26 Physical Security.** The objective and function of securing an organizational infrastructure, program, project, mission or activity and protecting their material, functional, control, information and human assets from interferences of a physical and material nature that can cause damage or result in unauthorized possession or control of such assets.
- A.27 Potential Vulnerability.** The characteristic of a system, system security procedures, internal controls or implementation that may represent a weakness in relation to the capabilities of a particular threat source and could be exploited by that threat source. (See also **Vulnerability**).
- A.28 Risk.** The potential for shortfalls with respect to achieving explicitly established and stated objectives. As applied to programs and projects, these objectives are translated into performance requirements, which may be related to mission execution domains (mission success, safety, physical and cybersecurity, cost and schedule) or institutional support for mission execution.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Risk is operationally characterized as a set of triplets:

- a. **The scenario(s)** leading to degraded performance with respect to one or more performance measures (e.g., scenarios leading to injury, fatality, destruction or compromise of key assets; scenarios leading to exceedance of mass limits; scenarios leading to cost overruns; scenarios leading to schedule slippage).
- b. **The likelihood(s)** (qualitative or quantitative) of those scenarios.
- c. **The consequence(s)** (qualitative or quantitative severity of the performance degradation) that would result if those scenarios were to occur.

Note: Uncertainties are included in the evaluation of likelihoods and identification of scenarios.

- A.29 Risk Acceptance Criterion.** A rule for determining whether a given organizational unit has the authority to decide to accept a risk.
- A.30 Risk Acceptance.** A decision to accept the level of risk that remains after implementation of available net-beneficial mitigations of a given risk. Risk acceptance can be deliberate or not, depending on whether the risk implications of the decision are recognized, acknowledged, and taken into account by the decision-maker(s); or whether they remain for any reason undesirably hidden or overlooked.
- A.31 Risk Board.** A group of people chartered to determine whether risks are valid or invalid (looking at its framework including planned risk burndown plan details) and properly owned by the identified organization or an outside entity and to approve and monitor the mitigation approach. The organizational unit leader or designee is the Risk Board Chair.
- A.32 Risk-Informed Decision Making.** A risk-informed decision-making process that uses a diverse set of performance measures (some of which are model-based risk metrics) along with other considerations within a deliberative process to inform decision making.
- A.33 Risk Leadership.** One of the “NASA Senior Leadership Focus Areas” referred to in NPD 1000.0C, it is there described as the application by NASA of a risk culture that has the goal of “increasing ‘decision velocity’ within a proper risk posture.” It is implemented from the higher levels of management by communicating to the work force a clear and balanced understanding of risk and benefits by defining and indicating appropriate technical standards and by ensuring the workforce has the proper experience and commitment to collaboration [adapted from NASA NPD 1000.0C].
- A.34 Risk Management.** A coordinated flow of activities to identify, evaluate and address risk with appropriate actions, which combines RIDM and CRM in an integrated framework. This is done in order to foster proactive management of risk items, to inform better decision making through better use of risk information and then to manage more effectively implementation of risk-related activities and actions by focusing the CRM process on the baseline performance requirements informed by the RIDM process.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- A.35 Risk Register.** The list of risks owned by the organizational unit determined to be valid by the Risk Board.
- A.36 Risk Posture.** An expression of the agreed upon limits of risk an organization’s leadership team is willing to accept in order to achieve one or more of its objectives. It is defined up front and in tandem with the development of objectives, consistently with Risk Leadership principles, and serves as the attitudinal framework for seeking a balance between the likelihood and benefit of achieving the objective(s), vs. the likelihood and severity of risks that may be introduced by the pursuit of achievement. Risk posture may change with time, in reflection of the evolution of leadership team attitudes or because of changes in priorities, but at any particular time, risk posture provides the de-facto basis for risk-informed decision making and continuous risk management.
- A.37 Risk Tolerance.** An expression of the limit of acceptable probability of a shortfall with respect to the achievement of an explicitly established and stated objective, which is defined consistently with the overall agreed upon Risk Posture and risk vs. benefit balance pursued by an organization, according to its established and communicated Risk Leadership principles.
- A.38 Safety.** In a risk-informed context, an overall condition that provides sufficient assurance that mishaps will not result from the mission execution or program implementation, or, if they occur, their consequences will be mitigated. This assurance is established by means of the satisfaction of a combination of deterministic criteria and risk-informed criteria.
- A.39 Scenario.** A sequence of events, such as an account or synopsis of a projected course of action or events.
- A.40 Strategic Risks.** The management of risks that threaten to jeopardize the organization’s attempts to fulfill its documented strategic objectives as defined in its Goddard Implementation Plan per evolving NASA’s Strategic Plan.
- A.41 Threat.** A circumstance or event with the potential to adversely impact organizational operations and missions, organizational assets, individuals, other organizations or the Nation through a system via unauthorized access, destruction, disclosure, modification of assets or information and/or failure or denial of service [adapted from NIST-SP 800-30, Rev. 1, Guide for Conducting Risk Assessments]. A “threat” may exist in a given context as an intrinsic characteristic of the related activities and events or be introduced by intentional adverse actions, including organized adversarial actions by an enemy entity, organization or nationⁱ. See also *Intentional Threat*.

- A.42 Threat Source.** An intent and method targeted at the intentional exploitation of a system characteristic, which may become a system weakness in relation to such an intent or method; or a situation and method that may accidentally trigger a vulnerability or system weaknessⁱⁱ [adapted from NIST-FIPS 200, Minimum Security Requirements for Federal Information and Information Systems].
- A.43 Threshold.** A level for a performance measure or a risk metric whose exceedance "triggers" management processes to rectify performance shortfalls.
- A.44 Uncertainty.** An imperfect state of knowledge or a variability resulting from a variety of factors including, but not limited to, lack of knowledge, applicability of information, physical variation, randomness or stochastic behavior, indeterminacy, judgment and approximation.
- A.45 Vulnerability.** A known weakness in the characteristics of a system, system security procedures, internal controls or implementation that could be exploited or triggered by a known threat source [adapted from NIST-SP 800-53, Rev. 5, Security and Privacy Controls for Information Systems and Organizations].

Appendix B – Acronyms

AOA	Analysis of Alternatives
CCF	Common Cause Failure
CIL	Critical Items List
CICP	Critical Items Control Plan (synonyms for CIL)
CMC	Center Management Council
CMO	Center Management and Operations
CRB	Center Risk Board
CRO	Center Risk Officer
CRM	Continuous Risk Management
CSO	Chief Safety and Mission Assurance Officer
EC	Executive Council
ECD	Estimated Completion Date
ERM	Enterprise Risk Management
FAR	Federal Acquisition Regulations
FMEA	Failure Modes and Effects Analysis
FTA	Fault Tree Analysis
HSE	Health, Safety and Environment
GMC	GSFC Management Council
GPD	Goddard Policy Directive
GPR	Goddard Procedural Requirements
GSFC	Goddard Space Flight Center
IOC	Institutional Operations Council
MD	Mission Directorate
MSD	Mission Support Directorate
MSR	Monthly Status Review
MRR	Maintenance, Repair and Replacement
MSE	Mission Systems Engineer
NASA	National Aeronautics and Space Administration
NFS	NASA Federal Acquisition Regulation Supplement
NPD	NASA Policy Directive
NPR	NASA Procedural Requirements
OSMA	Office of Safety and Mission Assurance
OU	Organizational Unit
PM	Project Manager
PMC	Program Management Council
POC	Point of Contact
PPBE	Planning, Programming, Budgeting, and Execution
PPP	Project Protection Plan
R-BAM	Risk-Based Acquisition Management
RIDM	Risk-Informed Decision Making

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO.	<u>GPR 7120.4E</u>
EFFECTIVE DATE:	<u>March 5, 2024</u>
EXPIRATION DATE:	<u>March 5, 2029</u>

Page 28 of 38

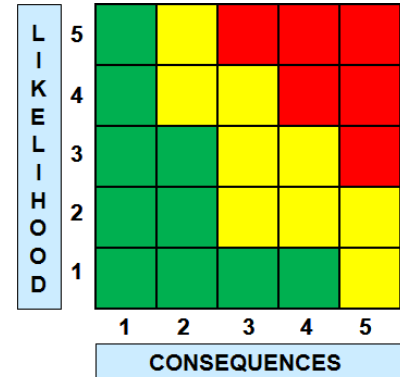
RM	Risk Management
RMP	Risk Management Plan
RMWG	Risk Management Working Group
SMA	Safety and Mission Assurance
TA	Technical Authority
UFE	Unallocated Future Expense

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT
<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Appendix C – GSFC Risk Scorecards and Risk Reporting Examples

A risk criticality of high, moderate (medium), or low is assigned to each risk using the Goddard risk matrix Figures 5 for program/project and use Figure 7 for Institutional risks. The instructions for the use of the risk scales are provided in Figure 6. Coordination/Integration of RIDM and CRM are reflected in Figure 1.

Likelihood	*Safety Estimated likelihood of Safety event occurrence	Technical Estimated likelihood of not meeting performance requirements	Cost/Schedule Estimated likelihood of not meeting cost or schedule commitment
5 - Very High	$(P_{SE} > 10^{-1})$	$(P_T > 50\%)$	$(P_{CS} > 75\%)$
4 - High	$(10^{-2} < P_{SE} \leq 10^{-1})$	$(25\% < P_T \leq 50\%)$	$(50\% < P_{CS} \leq 75\%)$
3 - Moderate	$(10^{-3} < P_{SE} \leq 10^{-2})$	$(15\% < P_T \leq 25\%)$	$(25\% < P_{CS} \leq 50\%)$
2 - Low	$(10^{-5} < P_{SE} \leq 10^{-3})$	$(2\% < P_T \leq 15\%)$	$(10\% < P_{CS} \leq 25\%)$
1- Very Low	$(10^{-6} < P_{SE} \leq 10^{-5})$	$(0.1\% < P_T \leq 2\%)$	$(2\% < P_{CS} \leq 10\%)$



Note: *Safety risk - The potential to cause injury to personnel or the public or to cause collateral damage to assets not owned by the project.

Consequence Categories						
Risk	1 Very Low	2 Low	3 Moderate	4 High	5 Very High	
Safety	Minor first aid treatment Required or collateral damage < \$5k	Minor injury or occupational illness or collateral damage \$5k - \$20K	Major injury or occupational illness or collateral damage of \$20k - \$100k	Severe injury or occupational illness or collateral damage of \$100k - \$500k	Death or permanently disabling injury or collateral damage > \$500k	HIGH RISK
Technical	Minor impact to lower priority full mission success criteria	Minor impact to higher priority full mission success criteria	Moderate impact to full mission success criteria. Minimum mission success criteria are achievable with margin	Major impact to full mission success criteria. Minimum mission success criteria are achievable	Minimum mission success criteria are not achievable	MODERATE RISK
Schedule	Minor impact to schedule milestones; accommodates within funded schedule margin (FSM), no impact to critical path	Impact to schedule milestones; accommodates within FSM, slight impact to critical path	Substantive Impact to schedule milestones; accommodates within FSM, moderate impact to critical path	Major impact to schedule milestones; major impact to critical path anticipating replan of activities; FSM anticipated to fall below GPR requirements	Cannot meet schedule and program milestones; anticipate a re-baseline	LOW RISK
Cost	0.5%-2% increase to the element ETC or 0.5%-1% impact on remaining project level development reserves through liens	≥2% but <5% increase to the element ETC or ≥1% but <5% impact on remaining project level development reserves through liens	≥5% but <7% increase to the element ETC or ≥5 but <20% impact on remaining project level development reserves through liens	≥7 but <10% increase to the element ETC or ≥20 but <50% impact on remaining project level development reserves through liens	≥10% increase to the element ETC or ≥50% impact on remaining project level development reserves through liens	

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Figure 5 - GSFC Program/Project Risk Matrix Standard Scale

Purpose: The Risk 5x5 is a qualitative tool used for executive level management reporting and independent assessment to communicate individual and composite risk in the context of mission success. This tool is not intended for rigorous risk assessment needs and should be used in conjunction with other analytical tools and risk analysis techniques for a complete understanding of any risk insight which may have implications over mission successes. Users should concentrate on and assess all the consequences of risk.

Likelihood Scale Explained (Estimated likelihood value P should be based on analytic techniques whenever possible.)

Safety: The potential to cause personnel injury or the public or to cause collateral damage to assets not owned by the project. The 5 groups of likelihood bins come directly from the NASA General Safety Program Requirements NPR 8715.3 The specified probability ranges (or likelihood bins) are the likelihood that an identified hazardous event will occur. These types of events should result directly in safety impacts, either as a mishap, an incident or accident based on assessments of such factors as location, exposure in terms of cycles or hours of operation, and affected population.

Technical: This scale of likelihood bins is used for ranking technical type of risks, which are measured using different scales from safety risks. A technical risk issue or event is primarily measured based on the likelihood of occurrence of such an event in terms of not meeting required minimum technical performances of a mission or drifting from a specified design and performance margin. Percentage values are used here to better indicate likelihood of any events of technical risk impact.

Cost: A cost risk is primarily measured based on the likelihood that a project will spend more money than was originally budgeted. It could lead to an overspend on the project, a reduction in project level reserves, or impacts to other elements as budget is reallocated to compensate for increased costs.

Schedule: A schedule risk is primarily measured based on the likelihood of failing to meet current schedule plan. It could lead to a delivery delay, a reduction in project slack and/or Funded Schedule Margin (FSM) or require a replan of activities to maintain schedule and/or the current level of project FSM.

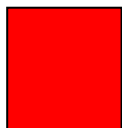
Consequences Scale Explained

Safety: Use this consequence scale to rank the severity levels of safety related risk consequences which result directly from occurrence of any hazardous events that have safety impact only.

Technical: Use this consequence scale to rank the severity levels of technical or mission performance related risk consequences that result directly from occurrence of any technical or mission operational events that have direct risk impact on meeting technical requirement or suffer from degraded design/operating margin or mission performance.

Cost: Use this consequence scale to rank the severity levels of cost risks that result directly from occurrence of any events (either technical or programmatic) having direct risk impact on established cost requirements.

Schedule: Use this consequence scale to rank the severity levels of schedule risks that result directly from occurrence of any events (either technical or programmatic) having direct risk impact on established schedule requirements



High risk – Generally unacceptable and needs concurrence of Center leadership or PMC



Moderate risk – Generally acceptable and needs concurrence of PMC



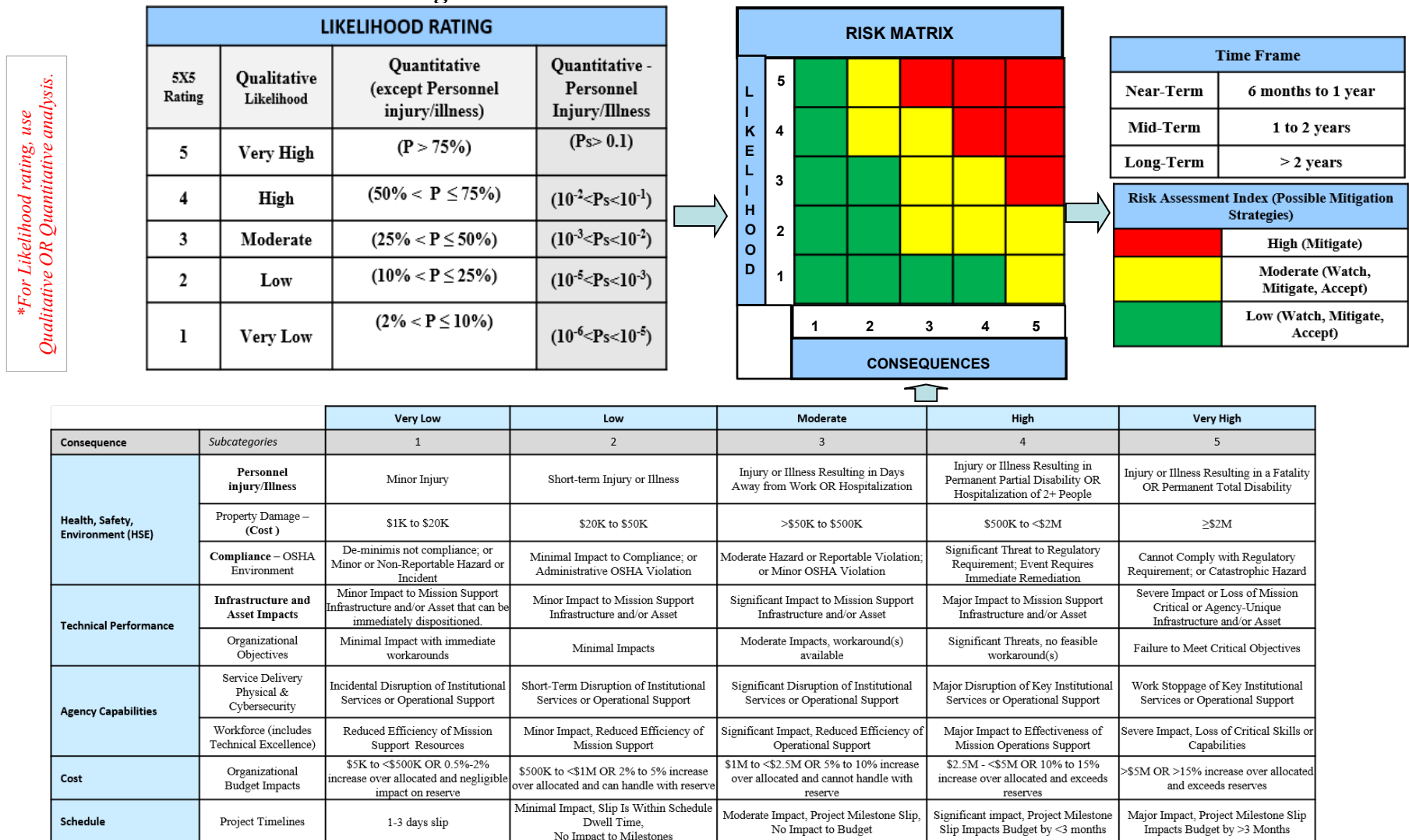
Low risk – No need for Center or PMC management attention

Figure 6: GSFC Risk Matrix Programmatic and Institutional Standard Scale Instructions

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Figure 7: GSFC Institutional Risk Score Card



CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.



GSFC RISK SCORECARD



Definitions

Risk Management: A coordinated flow of activities to identify, evaluate and address risk with appropriate actions, which combines RIDM and CRM in an integrated framework. This is done to foster proactive management of risk items, to inform better decision making through better use of risk information and then to manage more effectively implementation of risk-related activities and actions by focusing the CRM process on the baseline performance requirements informed by the RIDM process.

Risk: The potential for shortfalls with respect to achieving explicitly established and stated objectives. As applied to programs and projects, these objectives are translated into performance requirements, which may be related to mission execution domains (mission success, safety, physical and cybersecurity, cost, and schedule) or institutional support for mission execution.

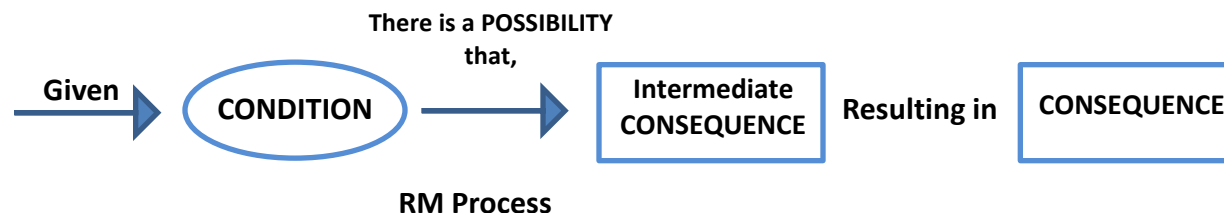
Center Risk: Requires Center Management resources or direction to resolve could have cross-cutting impacts that affect two or more GSFC organizations

Organizational Unit Risk: Requires Directorate Management direction and/or resources to resolve effects one or more Organizational Units

Sub-Organizational Unit Risk: Requires Division Management direction and/or resources to resolve effects on or more sub-organizations.

Concern: A candidate risk with insufficient or immature information to analyze or define mitigation options.

Writing a Risk Statement



Risk-informed Decision Making (RIDM): to inform GSFC decision-making through use of quantitative and qualitative risk information to establish baseline performance requirements for mission support organizations, programs, and projects.

Continuous Risk Management (CRM): A systematic and iterative process that efficiently identifies, analyzes, plans, tracks, controls, and communicates and documents risks associated with implementation of designs, plans, and processes and to manage risk associated with the implementation of baseline performance requirements.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

Top Risk List

Figure 8 is an example of a Risk List that presents a summary of the top risks for a program/project or other organizational unit. Although an organization and/or project may be tracking many risks, the risk matrix presented for management review typically includes the top ten. In the case of two or more risks have the same LxC value, the consequence takes precedence over Likelihood. Figure 9 and 10 reflects representative risk closure report example along with a water fall transition

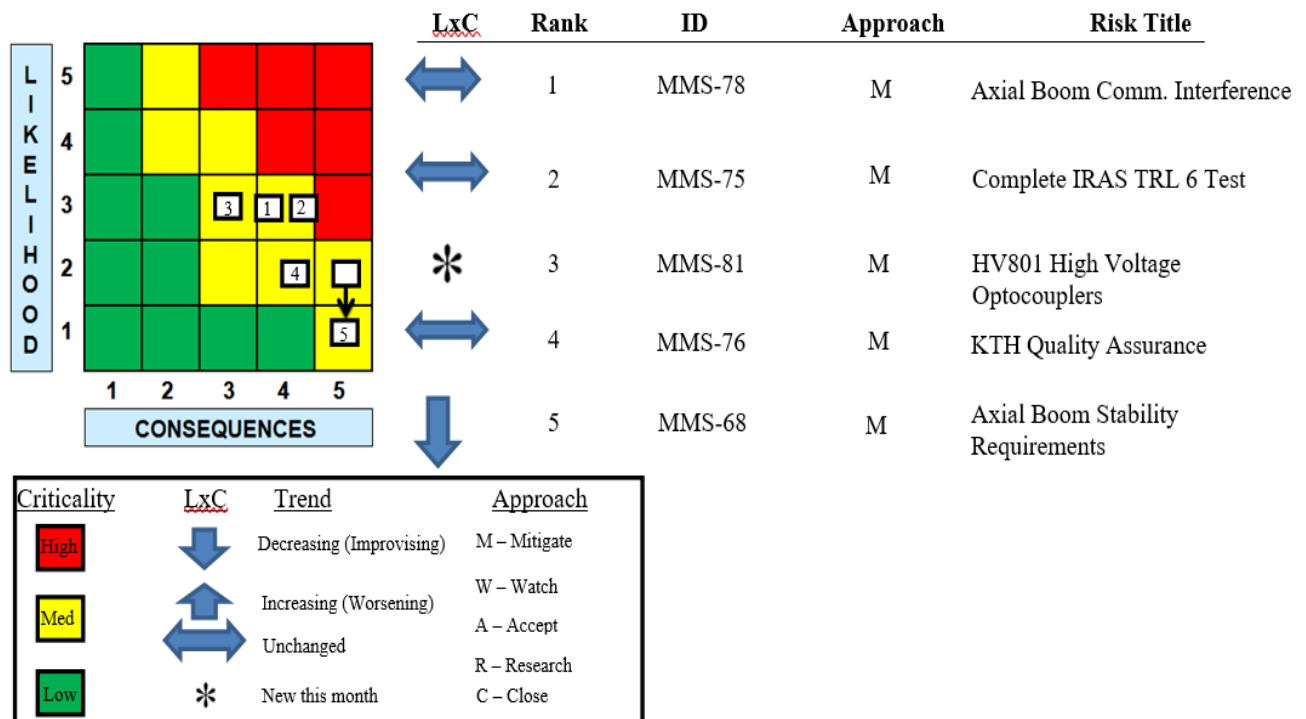


Figure 8 - Top Risk List Chart

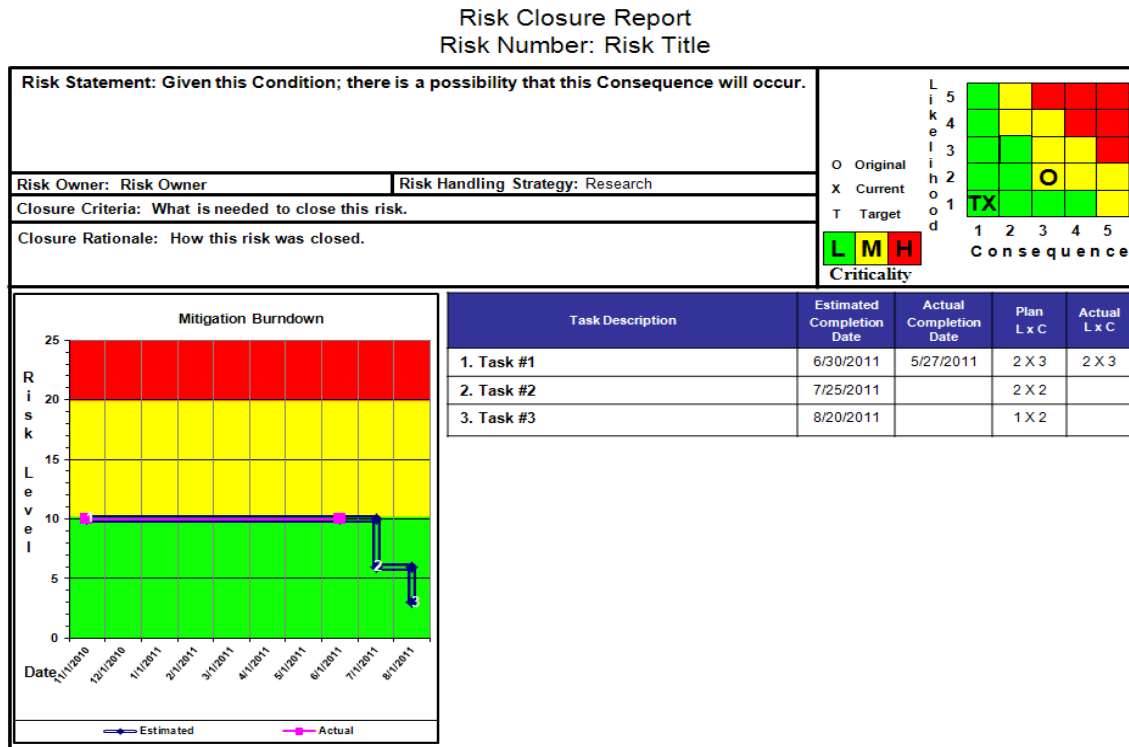


Figure 9: Risk Closure Report Example

Risk Matrix to Waterfall Translation

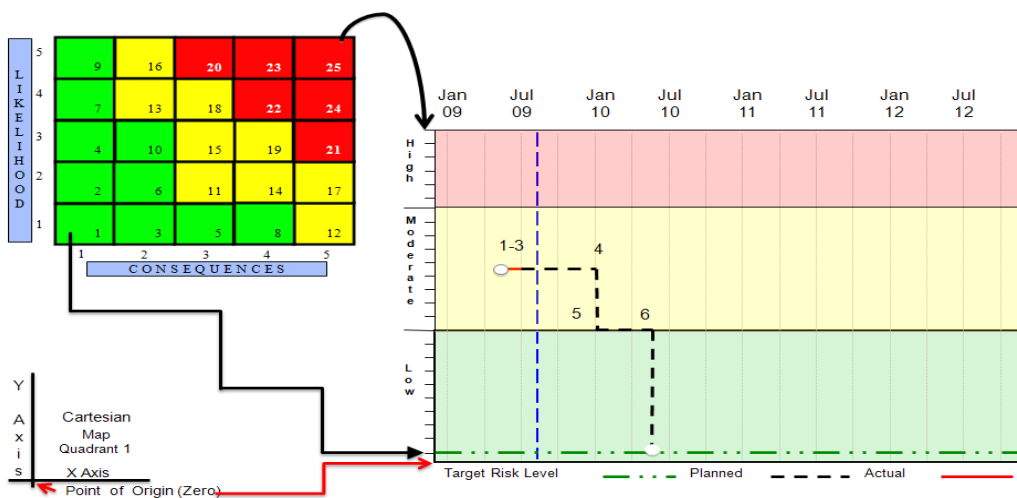


Figure 10 - Risk Matrix to Waterfall Translation Example

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT
<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

APPENDIX D: References

- D.1** Federal Information Security Modernization Act of 2014, Pub. L. 113-283, (2014).
- D.2** Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure), E.O. 13800 (2017).
- D.3** Acquisition Planning, 48 CFR pt.7.
- D.4** Contracting by Negotiation, 48 CFR pt.15.
- D.5** Acquisition Planning, 48 CFR pt.1807.
- D.6** Contracting by Negotiation, 48 CFR pt. 1815.
- D.7** NASA Federal Acquisition Regulations (FAR) Supplement (NFS) Parts 1807,15, 23, and 46
- D.8** OMB Circular A-123, Management's Responsibility for Enterprise Risk Management and Internal Control (07/15/2016).
- D.9** OMB Circular A-11, Preparing, Submitting, and Executing the Budget (08/01/2017).
- D.10** NPD 1000.0, Governance and Strategic Management Handbook.
- D.11** NPD 1000.3, The NASA Organization.
- D.12** NPD 1200.1, NASA Internal Control.
- D.13** NPD 1440.6, NASA Records Management.
- D.14** NPD 2810.1, NASA Information Security Policy.
- D.15** NPD 7120.4, NASA Engineering and Program/Project Management Policy.
- D.16** NPD 8700.1, NASA Policy for Safety and Mission Success
- D.17** NPD 8900.5, NASA Health and Medical Policy for Human Space Exploration.
- D.18** NPR 1441.1, NASA Records Management Program Requirements.
- D.19** NPR 7120.5, NASA Space Flight Program and Project Management Requirements.
- D.20** NPR 7123.1, NASA Systems Engineering Processes and Requirements.
- D.21** NPR 8705.4, Risk Classification for NASA Payloads.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

- D.22** NPR 8715.002B, NASA Emergency Management Program Procedural Requirements.
- D.23** NPR 8715.3, NASA General Safety Program Requirements
- D.24** NASA/SP-2011-3422, NASA Risk Management Handbook (including latest updates).
- D.25** Committee of Sponsoring Organizations of the Treadway Commission (COSO), Enterprise Risk Management - Integrated Framework (2004).
- D.26** GAO-14-704G, Standards for Internal Control in the Federal Government (the GAO Green Book).
- D.27** NIST-FIPS 200, Minimum Security Requirements for Federal Information and Information Systems, dated March 2006.
- D.28** NIST-SP 800-30, Rev. 1, Guide for Conducting Risk Assessments, dated September 18, 2012.
- D.29** NIST SP 800-37, Rev. 2, Risk Management Framework for Information Systems and Organizations: A system Life Cycle Approach for Security and Privacy.
- D.30** NIST-SP 800-53, Rev. 5, Security and Privacy Controls for Information Systems and Organizations, dated September 2020
- D.31** GPR 8700.4, Integrated Independent Reviews

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

CHANGE HISTORY LOG

Revision	Effective Date	Description of Changes
Baseline	12/07/01	Initial Release
A	06/14/05	Changes made to update organization and document references and/or distinguish requirements from recommendations in accordance with the NASA rules update mandate. Metrics added (P.9). P.10d – Added “documenting” to first sentence. 1.5 rewritten for clarity. 2.1 1st paragraph, last sentence modified to reflect all life cycles. 2.2b reworded. 2.3 – added Systems Engineer to review process. 2.4 rewritten for clarity. 2.11 – Introductory sentence reworded for clarity.
B	03/11/10	Administratively revised to reflect new owning organization. Administratively extended for 1 year from original expiration date.
C	10/28/10	Administratively Revised for correction.
D	08/09/12	a) Incorporation of new requirements from NPR 8000.4A such as RIDM (Risk-Informed Decision Making) b) Code 400 policy on “Liens, Threats, and Encumbrances” c) Code 200 Institutional Risk Management Plan Correlating GSFC-STD-0002 and GPR 7120.4D
D	07/25/2017	Administratively changed to update directive template and extended for 1 year.
D	07/24/2018	Administratively extended for 1 year.
D	07/24/2019	Administratively extended for 1 year.
D	07/28/2020	Administratively extended for 1 year.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT

<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.

DIRECTIVE NO. GPR 7120.4E
EFFECTIVE DATE: March 5, 2024
EXPIRATION DATE: March 5, 2029

Page 38 of 38

D	08/02/2021	Administratively extended for 1 year.
D	06/02/2022	Administratively extended for 6 months.
D	2/1/2023	Administratively extended for 6 months
E	3/5/2024	Key changes to streamline this document includes: (1) Updates related to NPR 8000.4 Rev B and Rev C changes such as: (a) Special rigor towards accepting safety and mission success risks by the Program/Project Manager including its concurrence by TAs. (b) Addressed Physical Security and Cybersecurity for Program/Projects and Institutional Risk categories while assessing risks (c) updated details of Lien and Encumbrances section. (d) updated Program/Project Risk score card Consequence table for programmatic details. (e) Revised Institutional Risk Score Cards in-line with the Mission Support Directorate (MSD) Risk scorecard. (f) Updated Appendix A, B, C and D in-line with all the changes in this document (2) Implementation of GSFC Risk Policy GPD 7120.4 (3) Addressed establishment of HQ/Mission Support Directorates offices at GSFC in its support role to the Center Director and influence of these to Goddard institutional operations.

CHECK THE GSFC DIRECTIVES MANAGEMENT SHAREPOINT AT
<https://nasa.sharepoint.com/sites/GSFC-GDMS/> TO VERIFY THAT THIS IS THE CORRECT VERSION PRIOR TO USE.